

الوحدة 17: أمن البريد الإلكتروني و DNS

SPF و DKIM و DMARC

SPF (Sender Policy Framework): يسجل عناوين IP المسموح لها بإرسال بريد نيابة عن نطاقك. ينشر كسجل TXT في DNS. يمنع انتحال البريد الإلكتروني (Email Spoofing).

DKIM (DomainKeys Identified Mail): يضيف توقيعاً رقمياً لرسائل البريد الإلكتروني. يتحقق خادم الاستلام من التوقيع عبر سجل DNS عام. يضمن عدم التلاعب بالرسالة أثناء النقل.

DMARC (Domain-based Message Authentication): يحدد سياسة التعامل مع الرسائل الفاشلة في SPF/DKIM. الخيارات: none (مراقبة فقط)، quarantine (عزل)، reject (رفض). يوفر تقارير عن محاولات الانتحال.

مثال: فحص SPF و DKIM باستخدام nslookup

```
nslookup -type=TXT example.com
nslookup -type=TXT _domainkey.example.com
```

`nslookup -type=TXT example.com` - طلب سجلات TXT من DNS للنطاق `example.com`. سجلات SPF تظهر بتنسيق: `v=spf1 include:_spf.google.com ~all`

`v=spf1` - إصدار `SPF`: يسمح لعناوين IP تابعة لخدمة أخرى بالبريد. `~all` (softfail) يضع علامة `all`? `neutral` ((أو `all` (hardfail) للرفض.

`nslookup -type=TXT _domainkey.example.com` - طلب سجل `_domainkey`. DKIM هو البادئة القياسية. يعود بسلسلة تحتوي على المفتاح العام للتوقيع.

`...v=DKIM1; h=sha256; p=MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQC` - إصدار DKIM، خوارزمية التجزئة، والمفتاح العام المشفر Base64.

مثال: فحص DMARC باستخدام dig (Linux/Mac)

```
dig TXT _dmarc.example.com +short
```

`dig` - أداة استعلام DNS متقدمة (أقوى من `nslookup`).

`TXT _dmarc.example.com` - سجل DMARC يُخزن في النطاق الفرعي `_dmarc` كنوع `TXT`.

`short+` - عرض النتيجة المختصرة (بدون تفاصيل الاستعلام). الإرجاع: `v=DMARC1; p=reject; rua=mailto:dmarc@example.com`

`v=DMARC1` - الإصدار. `p=reject` - سياسة رفض الرسائل الفاشلة. `rua` - عنوان البريد لإرسال التقارير.

DNSSEC (امتدادات أمن DNS)

يضيف توقعات رقمية لسجلات DNS. يحمي من هجمات تسمم ذاكرة التخزين المؤقت (DNS Cache Poisoning). يستخدم RRSIG (توقيع Resource Record) و DNSKEY (المفتاح العام).

أنواع السجلات: RRSIG (التوقيع الرقمي للسجل)، DNSKEY (مفتاح المنطقة)، DS (Delegation Signer) للربط بين المناطق.

Email Gateway و Sandboxing

Email Security Gateway: جهاز أو خدمة تقوم بتصفية البريد الإلكتروني قبل وصوله إلى الخادم الداخلي. يفحص المرفقات والروابط الضارة ويمنع Spam و Malware.

Sandboxing: بيئة معزولة (افتراضية) لتنفيذ الملفات المشبوهة. يراقب السلوك في بيئة آمنة قبل السماح بوصول البريد. يكتشف التهديدات غير المعروفة (Zero-day).

(Quick Quiz (MCQ

1. Which email authentication protocol uses DNS TXT records to specify which mail servers are authorized to send email for a domain

- a) DKIM
- b) DMARC
- c) SPF
- d) SMTP

Answer: c

2. ?What does DKIM use to verify the authenticity of an email message

- a) Sender IP address
- b) Cryptographic digital signature
- c) DNS lookup
- d) Spam filter rules

Answer: b

3. ?Which protocol tells receiving mail servers what to do with messages that fail SPF or DKIM checks

- a) SPF
- b) DKIM
- c) DMARC
- d) DNSSEC

Answer: c

4. ?What does DNSSEC protect against

- a) Email spoofing
- b) DNS cache poisoning and spoofing

- c) SQL injection
- d) Cross-site scripting

Answer: b

?What is the primary purpose of an email security gateway .5

- a) Encrypt DNS queries
- b) Filter and control inbound and outbound email for threats
- c) Manage firewall rules
- d) Monitor VPN connections

Answer: b